

**TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN**



**Nguyễn Văn Duy – 52400010
Lê Văn Quý – 52400153
Lê Khải Hoàn – 52400114**

HỆ THỐNG QUẢN LÝ CHI TIÊU CASHFLOW

BÁO CÁO CUỐI KỲ CÔNG NGHỆ PHẦN MỀM

THÀNH PHỐ HỒ CHÍ MINH, NĂM 2026

**TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN**



Nguyễn Văn Duy – 52400010

Lê Tiến Đạt – 52400105

Lê Khải Hoàn – 52400114

HỆ THỐNG QUẢN LÝ CHI TIÊU CASHFLOW

BÁO CÁO CUỐI KỲ CÔNG NGHỆ PHẦN MỀM

Người hướng dẫn

ThS. Võ Thị Kim Anh

THÀNH PHỐ HỒ CHÍ MINH, NĂM 2026

LỜI CẢM ƠN

Chúng em xin chân thành cảm ơn đến giảng viên ThS. Võ Thị Kim Anh. Trong quá trình nghiên cứu tìm hiểu và học tập môn học Công nghệ phần mềm, chúng em đã nhận được rất nhiều sự quan tâm, giúp đỡ nhiệt tình, hướng dẫn tận tâm và tâm huyết của cô Võ Thị Kim Anh. Cô đã giúp chúng em tích lũy thêm nhiều kiến thức về môn này để có thể hoàn thành được bài báo cáo này. Và bên cạnh đó, chúng em cũng cảm ơn những người bạn xung quanh cùng nhau hỗ trợ và làm nên bài báo cáo này. Chúng em xin gửi lời cảm ơn trân trọng đến thầy và các bạn đã cùng nhau làm bài báo cáo “Báo cáo cuối kỳ môn Công nghệ phần mềm”.

Mặc dù đã dành nhiều thời gian và nỗ lực để hoàn thành bài báo cáo này, nhưng do sự hạn chế về mặt kiến thức nên bài làm khó tránh khỏi những thiếu sót. Chúng em kính mong nhận được những lời góp ý của quý thầy, cô để bài làm này ngày càng hoàn thiện hơn. Chúng em xin chân thành cảm ơn!

TP. Hồ Chí Minh, ngày 12 tháng 05 năm 2026

Tác giả

Duy

Nguyễn Văn Duy

Quý

Lê Văn Quý

Hoàn

Lê Khải Hoàn

CÔNG TRÌNH ĐƯỢC HOÀN THÀNH TẠI TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG

Tôi xin cam đoan đây là công trình nghiên cứu của riêng chúng tôi và được sự hướng dẫn khoa học của ThS. Võ Thị Kim Anh. Các nội dung nghiên cứu, kết quả trong đề tài này là trung thực và chưa công bố dưới bất kỳ hình thức nào trước đây. Những số liệu trong các bảng biểu phục vụ cho việc phân tích, nhận xét, đánh giá được chính tác giả thu thập từ các nguồn khác nhau có ghi rõ trong phần tài liệu tham khảo.

Ngoài ra, trong Dự án còn sử dụng một số nhận xét, đánh giá cũng như số liệu của các tác giả khác, cơ quan tổ chức khác đều có trích dẫn và chú thích nguồn gốc.

Nếu phát hiện có bất kỳ sự gian lận nào tôi xin hoàn toàn chịu trách nhiệm về nội dung Dự án của mình. Trường Đại học Tôn Đức Thắng không liên quan đến những vi phạm tác quyền, bản quyền do tôi gây ra trong quá trình thực hiện (nếu có).

TP. Hồ Chí Minh, ngày 12 tháng 05 năm 2026

Tác giả

Duy

Nguyễn Văn Duy

Quý

Lê Văn Quý

Hoàn

Lê Khải Hoàn

TÓM TẮT

Dưới đây là nội dung báo cáo cuối kỳ của học phần Công nghệ phần mềm.

Bài báo cáo bao gồm các chương trình bày chi tiết từ cơ sở lý thuyết, phân tích thiết kế hệ thống, cho đến quá trình hiện thực hóa và đánh giá kết quả của Hệ thống Quản lý chi tiêu CashFlow.

Nội dung của từng chương trong bài báo cáo:

Chương 1: Thông tin và đánh giá nhóm: Chi tiết phân công nhiệm vụ cho từng thành viên và đánh giá tỷ lệ hoàn thành, tỷ lệ đóng góp.

Chương 2: Giới thiệu dự án: Lý do, mục tiêu áp dụng AI vào quản lý tài chính và bộ công nghệ cốt lõi.

Chương 3: Phân tích hệ thống: Phân tích các yêu cầu chức năng (nghệp vụ, bóc tách AI) và phi chức năng (bảo mật, hiệu năng).

Chương 4: Thiết kế hệ thống: Trực quan hóa bằng sơ đồ: Kiến trúc 3 lớp, thực thể mối quan hệ (ERD) và trình tự (Sequence).

Chương 5: Thực thi dự án: Trọng tâm lập trình: Tầng DAL (PDO, Transaction), BUS (logic), AI Service (Python) và GUI (Chart.js).

Chương 6: Kiểm thử và Phản biện AI: Các kịch bản kiểm thử và nhật ký Tech Lead tự rà soát, vá lỗi hệ thống với AI.

Chương 7: Tổng kết: Đánh giá thành quả, nhìn nhận hạn chế và đề xuất các tính năng nâng cấp trong tương lai.

MỤC LỤC

CHƯƠNG 1. THÔNG TIN VÀ ĐÁNH GIÁ NHÓM	1
1.1 Thành viên nhóm và phân công nhiệm vụ	1
1.2 Đánh giá tỷ lệ đóng góp	1
CHƯƠNG 2. MỞ ĐẦU VÀ TỔNG QUAN ĐỀ TÀI.....	2
2.1 Trình bày về đề tài và lý do thực hiện.....	2
2.2 Những yêu cầu của đề tài cần thực hiện	2
2.2.1 Yêu cầu về phạm vi và kỹ thuật.....	2
2.2.2 Yêu cầu về chức năng nghiệp vụ.....	3
2.3 Công nghệ sử dụng.....	4
CHƯƠNG 3. PHÂN TÍCH HỆ THỐNG	4
3.1 Quản lý xác thực và người dùng	4
3.1.1 Yêu cầu chức năng (<i>Functional Requirements – FR</i>).....	4
3.1.2 Yêu cầu phi chức năng (<i>Non-functional Requirements</i>).....	5
3.2 Quản lý giao dịch	5
3.2.1 Yêu cầu chức năng (<i>Functional Requirements – FR</i>).....	5
3.2.2 Yêu cầu phi chức năng (<i>Non-functional Requirements</i>).....	6
3.3 Quản lý danh mục	6
3.3.1 Yêu cầu chức năng (<i>Functional Requirements – FR</i>).....	6
3.3.2 Yêu cầu phi chức năng (<i>Non-functional Requirements</i>).....	6
3.4 Quản lý ngân sách	6
3.4.1 Yêu cầu chức năng (<i>Functional Requirements – FR</i>).....	6
3.4.2 Yêu cầu phi chức năng (<i>Non-functional Requirements</i>).....	7

3.5 Báo cáo, phân tích và thống kê	7
3.5.1 Yêu cầu chức năng (<i>Functional Requirements – FR</i>).....	7
3.5.2 Yêu cầu phi chức năng (<i>Non-functional Requirements</i>).....	7
3.6 Quản lý lịch tháng và ghi chú	8
3.6.1 Yêu cầu chức năng (<i>Functional Requirements – FR</i>).....	8
3.6.2 Yêu cầu phi chức năng (<i>Non-functional Requirements</i>).....	8
3.7 Cố vấn tài chính AI	8
3.7.1 Yêu cầu chức năng (<i>Functional Requirements – FR</i>).....	8
3.7.2 Yêu cầu phi chức năng (<i>Non-functional Requirements</i>).....	9
CHƯƠNG 4. THIẾT KẾ HỆ THỐNG	9
4.1 Kiến trúc hệ thống – Kiến trúc 3 tầng	9
4.1.1 Lớp giao diện (<i>GUI – Presentation Layer</i>).....	10
4.1.2 Lớp Nghiệp vụ (<i>BUS - Business Logic Layer</i>).....	10
4.1.3 Lớp Truy cập dữ liệu (<i>DAL - Data Access Layer</i>).....	10
4.2 Thiết kế cơ sở dữ liệu.....	10
4.3 Thiết kế các module chức năng.....	12
4.3.1 Chức năng xác thực người dùng (<i>Authentication</i>).....	13
4.3.2 Chức năng quản lý giao dịch (<i>Transaction</i>).....	14
4.3.3 Chức năng quản lý ngân sách (<i>Budget</i>).....	15
4.3.4 Chức năng Thêm giao dịch nhanh bằng AI (<i>AI Quick Add</i>).....	16
4.3.5 Chức năng Tư vấn AI (<i>AI Advisor</i>)	17
4.4 Thiết kế Bảo mật và Toàn vẹn dữ liệu	17
4.5 Thiết kế Giao diện và Trải nghiệm (UI/UX).....	18

CHƯƠNG 5. THỰC THI DỰ ÁN	20
5.1 Tầng Dữ liệu (Data Access Layer – DAL)	20
5.2 Tầng Nghiệp vụ (Business Logic Layer - BUS)	21
5.3 Tích hợp dịch vụ AI (Python Microservice)	21
5.4 Tầng Giao diện (Graphic User Interface - GUI)	22
CHƯƠNG 6. KIỂM THỬ VÀ PHẢN BIỆN AI	22
6.1 Bảng kịch bản kiểm thử	22
6.1.1 Xác thực người dùng (Authentication)	23
6.1.2 Quản lý giao dịch (Transaction Management)	23
6.1.3 Quản lý danh mục (Category Management)	24
6.1.4 Quản lý ngân sách (Budget Management)	24
6.1.5 Ghi chú hàng ngày (Daily Notes)	25
6.1.6 Cố vấn tài chính AI (AI Advisor)	25
6.1.7 Thêm nhanh bằng AI (AI Quick Add)	26
6.2 Nhật ký Virtual Tech Lead Audit (Phản biện và Tối ưu)	26
6.2.1 Đợt rà soát 1: Vi phạm nguyên tắc 3 tầng (Kiến trúc)	26
6.2.2 Đợt rà soát 2: Nút thắt hiệu năng AI - cURL Timeout (Hiệu năng)	27
6.2.3 Đợt rà soát 3: Lỗ hổng bảo mật tại AI Service Flask (Bảo mật)	27
6.2.4 Đợt rà soát 4: Bảo mật API Key (Dịch vụ AI)	27
CHƯƠNG 7. TỔNG KẾT	28
7.1 Kết quả đạt được	28
7.2 Hạn chế	29
7.3 Hướng phát triển tương lai	29

TÀI LIỆU THAM KHẢO	31
---------------------------------	-----------

CHƯƠNG 1. THÔNG TIN VÀ ĐÁNH GIÁ NHÓM

1.1 Thành viên nhóm và phân công nhiệm vụ

Dự án CashFlow được thực hiện bởi nhóm gồm 03 thành viên, với sự phân chia nhiệm vụ chuyên biệt hóa dựa trên kiến trúc 3 tầng (3-Layer Architecture) và các phân hệ chức năng riêng biệt.

Nguyễn Văn Duy – 52400010: Trưởng nhóm

- Viết báo cáo chính và tổng hợp sản phẩm.
- Xử lý module Đăng nhập và Xác thực (Auth).
- Thiết lập Middleware và Helpers hệ thống.
- Phát triển phân hệ AI Service (Python Flask).
- Phát triển module Người dùng (User).

Lê Văn Quý – 52400153: Thành viên

- Phát triển module Tổng quan (Dashboard).
- Phát triển module Lịch tháng (Calendar).
- Triển khai hệ cơ sở dữ liệu.
- Thiết kế và vẽ sơ đồ thực thể mối quan hệ (ERD), sơ đồ trình tự (Sequence Diagram) và hỗ trợ biên tập nội dung báo cáo.

Lê Khải Hoàn – 52400114: Thành viên

- Phát triển module Giao dịch (Transactions).
- Phát triển module Ngân sách (Budgets).
- Phát triển module Danh mục (Categories).
- Quay video giới thiệu sản phẩm.

1.2 Đánh giá tỷ lệ đóng góp

Toàn bộ cả ba thành viên trong nhóm đều tham gia tích cực, tuân thủ đúng deadline nội bộ và hoàn thành xuất sắc các nhiệm vụ được giao. Dưới đây là tỉ lệ đóng góp được cả nhóm thống nhất và xác nhận:

Họ và tên	Vai trò trong nhóm	Mức độ hoàn thành	Tỷ lệ đóng góp
Nguyễn Văn Duy	Trưởng nhóm	100%	33.4%
Lê Văn Quý	Thành viên	100%	33.4%
Lê Khải Hoàn	Thành viên	100%	33.4%

CHƯƠNG 2. MỞ ĐẦU VÀ TỔNG QUAN ĐỀ TÀI

2.1 Trình bày về đề tài và lý do thực hiện

Trong bối cảnh nền kinh tế số phát triển mạnh mẽ, việc quản lý tài chính cá nhân trở thành một kỹ năng sống còn. Tuy nhiên, phần lớn người dùng hiện nay gặp phải hai rào cản lớn:

- **Sự phức tạp trong nhập liệu:** Việc phải mở ứng dụng và điền thủ công từng con số khiến người dùng dễ nản lòng và bỏ cuộc sau vài ngày.
- **Thiếu tính định hướng:** Dữ liệu thu chỉ nếu chỉ là những con số vô hồn sẽ không giúp người dùng hiểu được thói quen chi tiêu hoặc nhận ra các rủi ro tài chính tiềm ẩn.

Hệ thống CashFlow ra đời với mục tiêu phá vỡ các rào cản này bằng cách tích hợp Trí tuệ nhân tạo (AI), cho phép người dùng nhập liệu bằng ngôn ngữ tự nhiên và nhận lời khuyên tài chính thông minh, giúp việc quản lý tiền bạc trở nên đơn giản và có chiều sâu hơn.

2.2 Những yêu cầu của đề tài cần thực hiện

Để đảm bảo hệ thống hoạt động hiệu quả, bám sát thực tiễn và đáp ứng đúng tiêu chí đánh giá của học phần, đề tài đặt ra các yêu cầu cụ thể về phạm vi, kỹ thuật và chức năng nghiệp vụ như sau:

2.2.1 Yêu cầu về phạm vi và kỹ thuật

Dự án được giới hạn và chuẩn hóa dựa trên các tiêu chí kỹ thuật phần mềm nghiêm ngặt:

- **Về phạm vi:** Tập trung vào đối tượng người dùng cá nhân; hỗ trợ quản lý Thu - Chi, thiết lập ngân sách theo tháng và phân tích dữ liệu thông qua biểu đồ

trực quan. Phân hệ AI tập trung vào hai tác vụ: Bóc tách dữ liệu giao dịch và đưa ra lời khuyên tài chính.

- **Về kỹ thuật:**

- **Kiến trúc:** Triển khai theo mô hình 3 lớp (3-Layer Architecture) để tách biệt hoàn toàn Giao diện (GUI), Xử lý nghiệp vụ (BUS) và Truy cập dữ liệu (DAL).
- **Bảo mật:** Thực thi các cơ chế bảo vệ chống tấn công CSRF bằng mã Token ngẫu nhiên, ngăn chặn SQL Injection thông qua PDO Prepared Statements và bảo mật thông tin nhạy cảm qua tệp `.env`.
- **Hiệu năng:** Hệ thống phải đảm bảo phản hồi nhanh (dưới 5 giây cho các tác vụ AI) và giao diện tương thích hoàn toàn với các thiết bị di động (Responsive Design).

2.2.2 Yêu cầu về chức năng nghiệp vụ

Hệ thống cung cấp đầy đủ các mô-đun chức năng quản lý nghiệp vụ, cụ thể:

- **Quản lý xác thực và người dùng:** Đăng ký tài khoản, đăng nhập, quên mật khẩu (gửi email), thiết lập mật khẩu lần đầu và quản lý hồ sơ cá nhân (đổi avatar, cập nhật thông tin).
- **Quản lý giao dịch:** Ghi chép các khoản thu và chi hàng ngày. Cho phép thêm, sửa, xóa và tìm kiếm lịch sử giao dịch.
- **Quản lý danh mục:** Quản lý các loại hình thu/chi (Ví dụ: Ăn uống, Lương, Nhà cửa, Giải trí...).
- **Quản lý ngân sách:** Cho phép người dùng thiết lập hạn mức chi tiêu cho từng danh mục theo tháng. Hệ thống tự động tính toán phần trăm đã sử dụng.
- **Báo cáo, phân tích và thống kê:** Tổng hợp dữ liệu để vẽ biểu đồ cơ cấu chi tiêu và xu hướng dòng tiền.
- **Quản lý lịch tháng và ghi chú:** Hiện thị giao dịch dưới dạng lịch tháng và cho phép đính kèm ghi chú cho từng ngày.
- **Cố vấn tài chính AI:**

- **AI Quick Add:** Sử dụng xử lý ngôn ngữ tự nhiên (NLP) để bóc tách dữ liệu từ nội dung (Ví dụ: "Ăn phở 50k") và tự động tạo giao dịch.
- **AI Advisor:** Chatbot tư vấn dựa trên dữ liệu thực tế như cảnh báo chi tiêu quá mức, đưa ra lời khuyên tiết kiệm, dự báo số dư cuối tháng và tóm tắt ngắn gọn tình hình chi tiêu theo tháng.

2.3 Công nghệ sử dụng

Hệ thống tận dụng sức mạnh của sự kết hợp giữa lập trình website truyền thống và microservice AI:

Thành phần	Công nghệ / Thư viện	Vai trò
Backend Core	PHP 8.1+	Xử lý logic 3 tầng, điều phối dữ liệu và Middleware.
Database	MySQL (MariaDB)	Lưu trữ dữ liệu quan hệ, xử lý Transaction và ràng buộc toàn vẹn.
AI Service	Python (Flask)	Xây dựng dịch vụ Web gọn nhẹ để kết nối với mô hình ngôn ngữ lớn.
AI Model	Gemini 3.1 Flash Lite	"Bộ não" của hệ thống, xử lý ngôn ngữ tự nhiên và bóc tách dữ liệu JSON.
Frontend	Bootstrap 5, Chart.js, JS	Thiết kế giao diện hiện đại và vẽ biểu đồ thống kê động.
Thư viện hỗ trợ	PHPMailer, Dotenv	Xử lý gửi email xác thực và quản lý biến môi trường bảo mật.

CHƯƠNG 3. PHÂN TÍCH HỆ THỐNG

Trong chương này, nhóm sẽ phân tích các yêu cầu chức năng và phi chức năng của hệ thống theo đầy đủ 7 mô-đun đã được liệt kê bên trên.

3.1 Quản lý xác thực và người dùng

3.1.1 Yêu cầu chức năng (Functional Requirements – FR)

Mã FR	Tên chức năng	Mô tả chi tiết	Tiêu chí chấp nhận
FR-101	Đăng ký tài khoản	Tạo tài khoản bằng Email và Tên.	Gửi email kích hoạt. Không trùng email.
FR-102	Đăng nhập	Truy cập bằng Email/Mật khẩu.	Sai thông tin báo lỗi. Bắt buộc đổi MK nếu lần đầu.
FR-103	Thiết lập mật khẩu	Bắt buộc đổi mật khẩu an toàn.	Mật khẩu tối thiểu 6 ký tự. Băm bằng Bcrypt.
FR-104	Quên mật khẩu	Gửi mail đặt lại mật khẩu.	Link xác thực an toàn qua mail.
FR-105	Quản lý hồ sơ	Cập nhật avatar/thông tin.	Upload ảnh hợp lệ, tự động đổi tên file.

3.1.2 Yêu cầu phi chức năng (Non-functional Requirements)

- **Security (NFR-101):** Toàn bộ mật khẩu phải được băm bằng Bcrypt trước khi lưu vào CSDL.
- **Security (NFR-102):** Sử dụng CSRF Token cho mọi yêu cầu thay đổi dữ liệu (POST).
- **Usability (NFR-103):** Thông báo lỗi đăng nhập phải rõ ràng nhưng không tiết lộ lý do cụ thể (tránh dò tìm tài khoản).

3.2 Quản lý giao dịch

3.2.1 Yêu cầu chức năng (Functional Requirements – FR)

Mã FR	Tên chức năng	Mô tả chi tiết	Tiêu chí chấp nhận
FR-201	Thêm giao dịch	Nhập số tiền, danh mục, ngày, note.	Số tiền > 0. Tự động cập nhật số dư.
FR-202	Danh sách giao dịch	Hiển thị lịch sử Thu/Chi.	Phân biệt màu sắc Thu (Xanh) - Chi (Đỏ).
FR-203	Sửa/Xóa giao dịch	Điều chỉnh thông tin sai.	Cập nhật số dư lập tức. Bảo mật quyền sở hữu.

FR-204	Tìm kiếm và Lọc	Lọc theo ngày, loại, từ khóa.	Kết quả trả về qua AJAX (không load trang)
---------------	-----------------	-------------------------------	--

3.2.2 Yêu cầu phi chức năng (Non-functional Requirements)

- **Integrity (NFR-201):** Số tiền giao dịch phải sử dụng kiểu dữ liệu decimal(15,2) để tránh sai số làm tròn.
- **Performance (NFR-202):** Tìm kiếm giao dịch phải có thời gian phản hồi dưới 1 giây với dữ liệu 10,000 dòng.
- **Performance (NFR-203):** Sử dụng Index trên cột transaction_date và user_id để tối ưu truy vấn.

3.3 Quản lý danh mục

3.3.1 Yêu cầu chức năng (Functional Requirements – FR)

Mã FR	Tên chức năng	Mô tả chi tiết	Tiêu chí chấp nhận
FR-301	Danh mục hệ thống	Các danh mục mặc định.	Người dùng không được xóa/sửa mục hệ thống.
FR-302	Danh mục cá nhân	Người dùng tự tạo thêm.	Hỗ trợ cấu trúc phân cấp (Cha - Con).
FR-303	Sửa/Xóa danh mục	Tùy chỉnh danh mục riêng.	Không cho xóa nếu đang có giao dịch liên kết.

3.3.2 Yêu cầu phi chức năng (Non-functional Requirements)

- **Reliability (NFR-301):** Hệ thống phải duy trì tính toàn vẹn tham chiếu (Foreign Key) khi thao tác với danh mục.
- **Usability (NFR-302):** Giao diện chọn danh mục phải trực quan, thể hiện rõ cấp bậc Cha-Con.

3.4 Quản lý ngân sách

3.4.1 Yêu cầu chức năng (Functional Requirements – FR)

Mã FR	Tên chức năng	Mô tả chi tiết	Tiêu chí chấp nhận
FR-401	Thiết lập ngân sách	Đặt hạn mức chi tiêu theo tháng.	Mỗi danh mục có tối đa 1 hạn mức/tháng.
FR-402	Cảnh báo vượt hạn	Theo dõi tiến độ chi tiêu.	Thanh Progress bar chuyển đỏ khi chi > 100%.
FR-403	Tự động thừa kế	Copy ngân sách sang tháng mới.	Tự thực hiện khi người dùng xem tháng chưa cấu hình.

3.4.2 Yêu cầu phi chức năng (Non-functional Requirements)

- **Accuracy (NFR-401):** Tỷ lệ phần trăm sử dụng ngân sách phải được tính toán chính xác dựa trên tổng chi thực tế của danh mục đó trong tháng.
- **Performance (NFR-402):** Tính toán ngân sách phải được thực hiện ở phía Server để đảm bảo tính nhất quán.

3.5 Báo cáo, phân tích và thống kê

3.5.1 Yêu cầu chức năng (Functional Requirements – FR)

Mã FR	Tên chức năng	Mô tả chi tiết	Tiêu chí chấp nhận
FR-501	Dashboard Tổng quan	Xem Thu, Chi, Số dư hiện tại.	Cập nhật số liệu Real-time.
FR-502	Biểu đồ Cơ cấu	Tỷ trọng chi tiêu theo mục.	Biểu đồ tròn Chart.js sinh động, có chú thích.
FR-503	Biểu đồ Dòng tiền	Xu hướng tài chính qua thời gian.	Biểu đồ đường, hỗ trợ lọc theo tuần/tháng.

3.5.2 Yêu cầu phi chức năng (Non-functional Requirements)

- **Usability (NFR-501):** Biểu đồ phải tương thích hoàn hảo trên các kích thước màn hình khác nhau (Responsive).

- **Performance (NFR-502):** Sử dụng các câu lệnh SQL tối ưu (như Pivot/Aggregation) để giảm tải cho Web Server.

3.6 Quản lý lịch tháng và ghi chú

3.6.1 Yêu cầu chức năng (Functional Requirements – FR)

Mã FR	Tên chức năng	Mô tả chi tiết	Tiêu chí chấp nhận
FR-601	Lịch giao dịch	Xem biến động tiền theo ngày.	Hiển thị popup chi tiết khi click vào ngày.
FR-602	Ghi chú tài chính	Lưu lời nhắc cho ngày cụ thể.	Hiển thị icon ghim trên lịch để nhận diện.

3.6.2 Yêu cầu phi chức năng (Non-functional Requirements)

- **Performance (NFR-601):** Dữ liệu giao dịch trên lịch phải được tải bất đồng bộ (Lazy loading) để tránh làm chậm trang.
- **Usability (NFR-602):** Thao tác chuyển tháng trên lịch phải mượt mà, không giật lag.

3.7 Cố vấn tài chính AI

3.7.1 Yêu cầu chức năng (Functional Requirements – FR)

Mã FR	Tên chức năng	Mô tả chi tiết	Tiêu chí chấp nhận
FR-701	AI Quick Add	Chuyển câu nói thành giao dịch.	"Ăn tối 100k" -> amount=100000, type=expense.
FR-702	AI Advisor	Tư vấn tài chính chuyên sâu.	Chế độ: Cảnh báo, Lời khuyên, Dự báo, Tóm tắt.
FR-703	Cấu trúc phản hồi	Ép AI trả lời theo format.	Luôn có 3 phần: TỔNG QUÁT, CỤ THỂ, KẾT LUẬN.

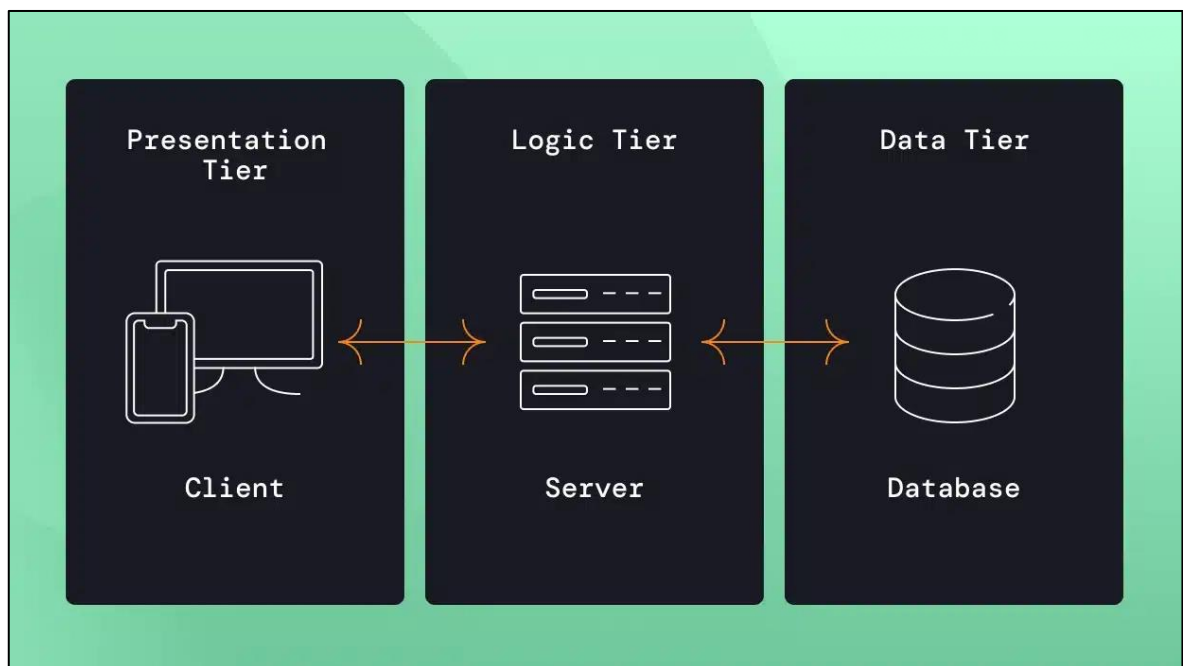
FR-704	Giới hạn Token	Kiểm soát lượt sử dụng.	Tối đa 3 lượt hỏi/người dùng/ngày.
---------------	----------------	-------------------------	------------------------------------

3.7.2 Yêu cầu phi chức năng (Non-functional Requirements)

- **Reliability (NFR-701):** Hệ thống phải thông báo lỗi thân thiện nếu Server Python bị ngắt kết nối hoặc API Gemini bị lỗi.
- **Security (NFR-702):** API Key của Gemini phải được bảo mật tuyệt đối trong file `.env`, không bao giờ để lộ ở phía Client (JavaScript).
- **Performance (NFR-703):** Thời gian xử lý của AI không được vượt quá 30 giây cho một yêu cầu phức tạp.
- **Maintainability (NFR-704):** Tách biệt logic AI thành dịch vụ Python riêng để dễ dàng nâng cấp model AI trong tương lai (ví dụ từ Gemini 3.0 lên 3.1).

CHƯƠNG 4. THIẾT KẾ HỆ THỐNG

4.1 Kiến trúc hệ thống – Kiến trúc 3 tầng



Hình 4-1 Minh họa kiến trúc 3 tầng

Hệ thống CashFlow được xây dựng dựa trên sự kết hợp giữa kiến trúc 3 lớp (3-Layer Architecture) cho phân lỗi và mô hình Microservice hạng nhẹ cho phân hệ

Trí tuệ nhân tạo (AI). Việc tách biệt các lớp không chỉ giúp hệ thống dễ dàng bảo trì, mở rộng mà còn tối ưu hóa tài nguyên máy chủ.

4.1.1 Lớp giao diện (GUI – Presentation Layer)

- **Thành phần:** HTML5, CSS3, JavaScript và hệ thống Controllers trong thư mục GUI/controllers/.
- **Nhiệm vụ:** Đây là tầng "tiếp tân", nhận yêu cầu từ trình duyệt, kiểm tra xác thực người dùng (Session), token bảo mật và hiển thị kết quả. Toàn bộ tương tác được thực hiện thông qua Fetch API để đạt được trải nghiệm Single Page Application (SPA), giúp trang web không cần tải lại khi thực hiện các tác vụ Thêm/Sửa/Xóa.

4.1.2 Lớp Nghiệp vụ (BUS - Business Logic Layer)

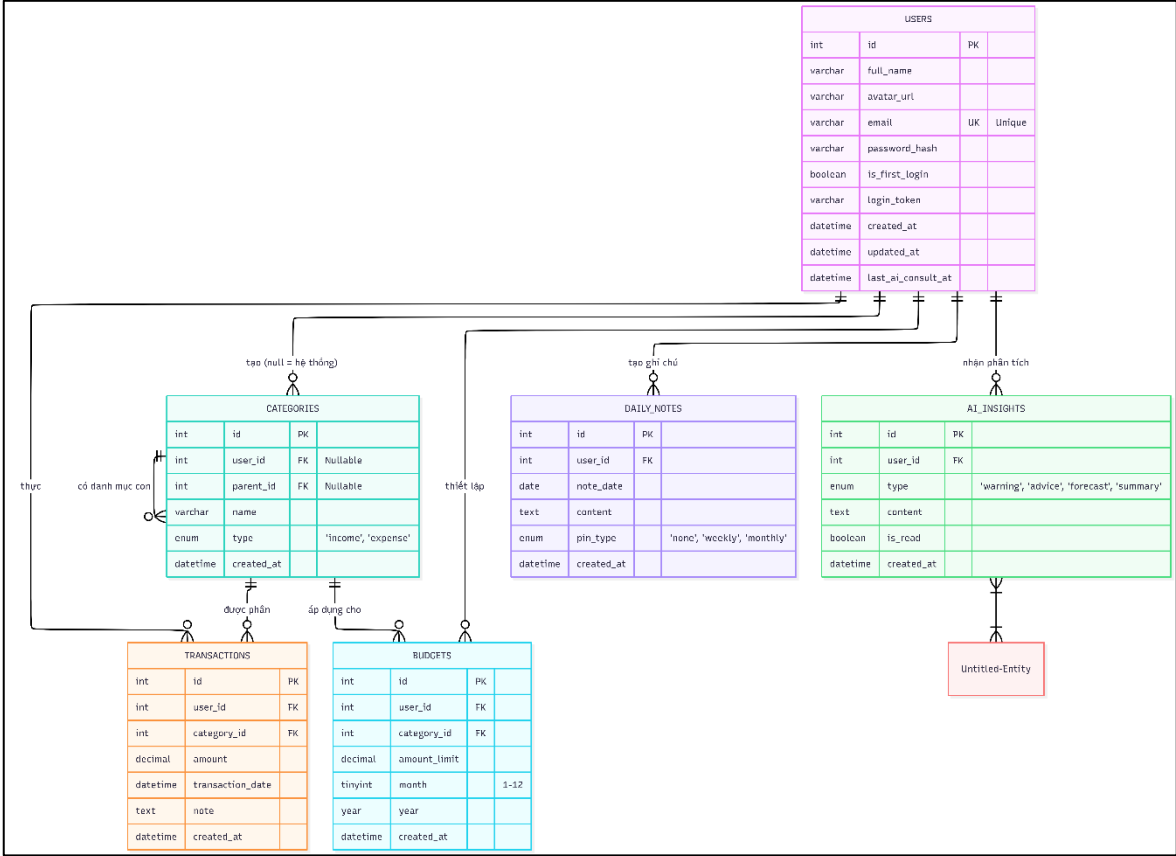
- **Thành phần:** Các lớp xử lý logic trong thư mục source/BUS/.
- **Nhiệm vụ:** Đây là "bộ não" trung tâm, nơi thực thi các quy tắc nghiệp vụ như: kiểm tra hạn mức ngân sách, nội suy thời gian ghi chú lịch, và tính toán số liệu thống kê. Lớp BUS đóng vai trò điều phối, gọi dịch vụ AI (Python) thông qua cURL và ra lệnh cho DAL thực thi dữ liệu.

4.1.3 Lớp Truy cập dữ liệu (DAL - Data Access Layer)

- **Thành phần:** Các lớp thao tác CSDL trong thư mục source/DAL/.
- **Nhiệm vụ:** Thực hiện các truy vấn SQL thông qua PDO (PHP Data Objects). Tầng này chịu trách nhiệm duy nhất là đảm bảo dữ liệu được đọc/ghi một cách chính xác và an toàn nhất, tuyệt đối không chứa các logic nghiệp vụ phức tạp.

4.2 Thiết kế cơ sở dữ liệu

Cơ sở dữ liệu của dự án được thiết kế chuẩn hóa để đảm bảo tính toàn vẹn và tránh dư thừa. Hệ thống bao gồm 6 thực thể cốt lõi:



Hình 4-2 ERD

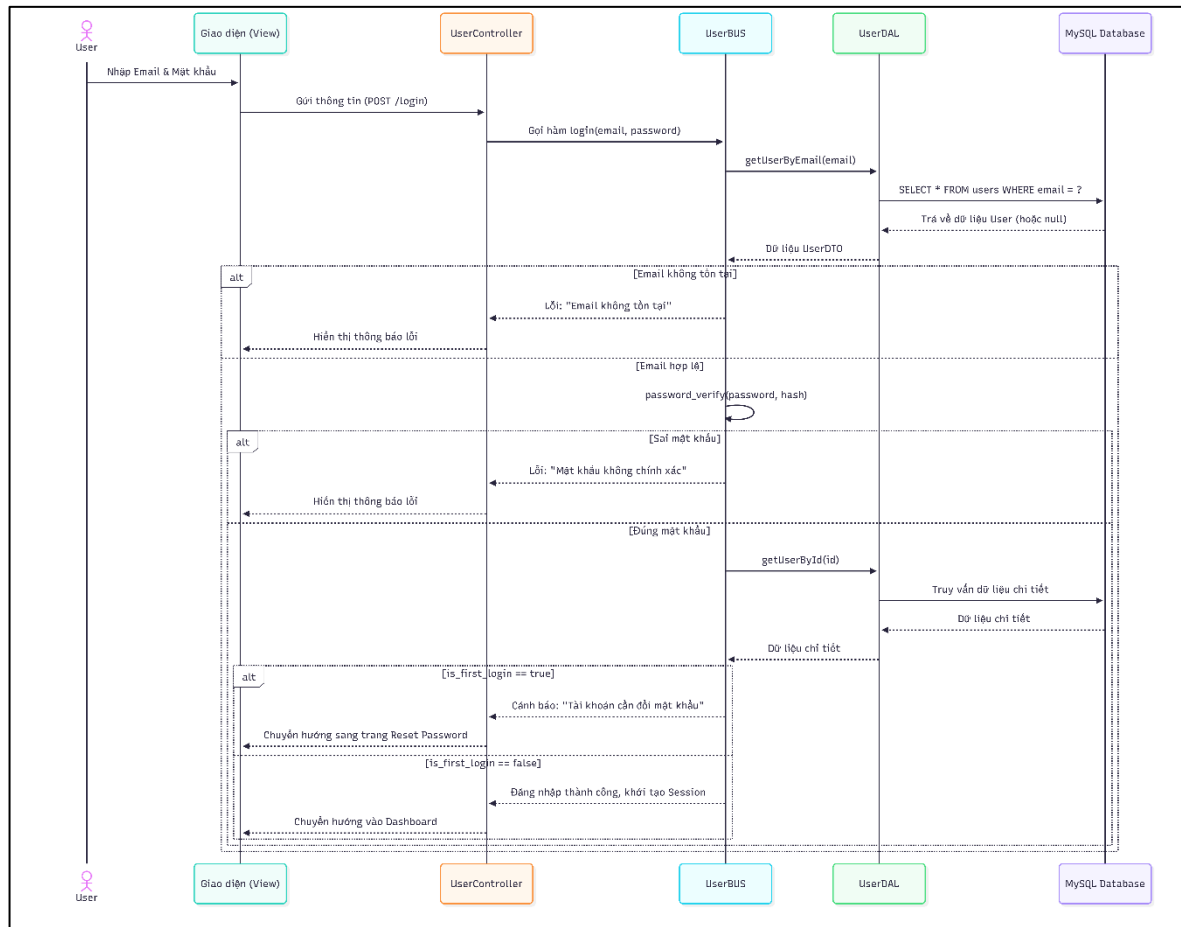
Tên bảng	Mô tả	Các trường chính
users	Lưu trữ thông tin cá nhân và mật khẩu đã được băm	id, full_name, email, password_hash, is_first_login, avatar_url, last_ai_consult_at, update_at, created_at, login_token

categories	Quản lý danh mục thu/chi với cấu trúc phân cấp qua parent_id	id, user_id, name, parent_id, type (income/expense)
transactions	Lưu trữ chi tiết dòng tiền, liên kết chặt chẽ với Users và Categories	id, user_id, category_id, amount, transaction_date, note
budgets	Quản lý hạn mức chi tiêu theo tháng, hỗ trợ tính năng tự động sao chép (clone) logic.	id, user_id, category_id, amount_limit, month, year
daily_notes	Lưu trữ ghi chú lịch, hỗ trợ ghim (pin) theo chu kỳ tuần/tháng	id, user_id, note_date, content, pin_type
ai_insights	Lưu trữ lịch sử tư vấn, giúp giảm thiểu việc gọi API dư thừa	id, user_id, type, content, is_read

4.3 Thiết kế các module chức năng

Phần này mô tả luồng tương tác giữa các lớp (GUI – BUS – DAL) thông qua các sơ đồ trình tự (Sequence Diagrams) cho 4 chức năng cốt lõi.

4.3.1 Chức năng xác thực người dùng (Authentication)

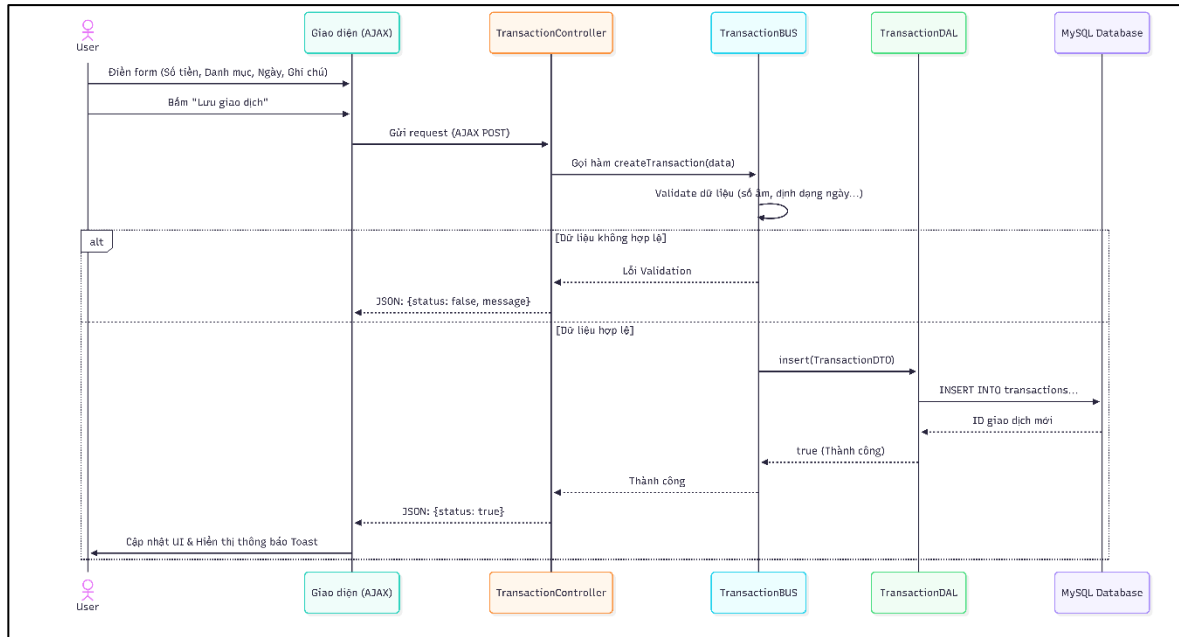


Hình 4-3 Mô tả luồng đăng nhập và kiểm tra session của người dùng

Phân tích luồng xử lý:

- **Tiếp nhận:** GUI nhận thông tin từ người dùng và chuyển tiếp đến UserBUS để xử lý logic nghiệp vụ.
- **Truy vấn:** UserBUS yêu cầu UserDAL lấy thông tin người dùng dựa trên email. Lớp DAL thực hiện truy vấn SQL an toàn để lấy password_hash.
- **Xác thực:** BUS sử dụng hàm password_verify() để so khớp mật khẩu nhập vào với mã băm trong CSDL.
- **Phản hồi:** Nếu thành công, Controller sẽ khởi tạo Session PHP và điều hướng người dùng. Nếu thất bại, hệ thống trả về thông báo lỗi thân thiện mà không tiết lộ thông tin chi tiết.

4.3.2 Chức năng quản lý giao dịch (Transaction)

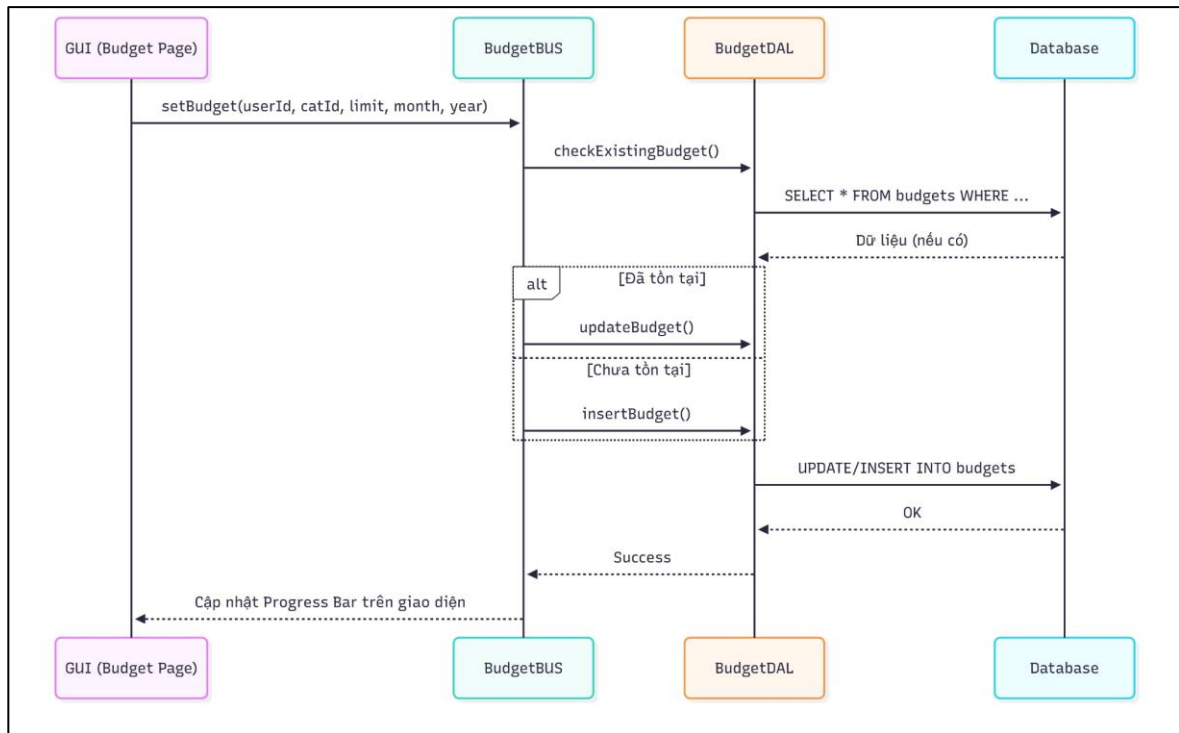


Hình 4-4 Mô tả luồng thêm mới một giao dịch tài chính.

Phân tích luồng xử lý:

- **Nhập liệu:** Người dùng điền thông tin vào Modal thêm giao dịch. JavaScript tại GUI sẽ đóng gói dữ liệu và gửi yêu cầu AJAX (POST) đến hệ thống.
- **Kiểm tra:** TransactionBUS thực hiện kiểm tra tính hợp lệ của dữ liệu (Validate): số tiền phải là số dương, danh mục phải thuộc quyền sở hữu của người dùng.
- **Lưu trữ:** Dữ liệu được đóng gói vào đối tượng DTO và chuyển cho TransactionDAL để thực hiện câu lệnh INSERT vào bảng transactions.
- **Đồng bộ:** Sau khi lưu thành công, hệ thống phản hồi JSON về phía Client để JavaScript cập nhật lại giao diện (danh sách giao dịch và số dư) mà không cần tải lại toàn bộ trang.

4.3.3 Chức năng quản lý ngân sách (Budget)

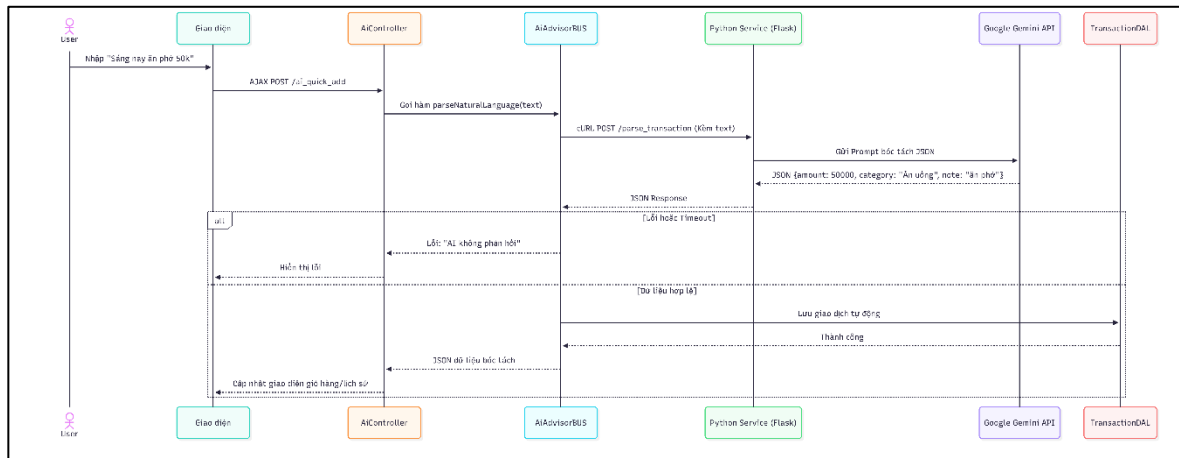


Hình 4-5 Mô tả luồng thiết lập hạn mức chi tiêu cho một danh mục.

Phân tích luồng xử lý:

- **Thiết lập:** Người dùng chọn danh mục và đặt hạn mức chi tiêu cho một tháng cụ thể.
- **Logic kiểm tra:** BudgetBUS trước tiên sẽ kiểm tra xem danh mục đó đã có hạn mức cho tháng đó chưa.
- **Xử lý DB:** Tùy vào kết quả kiểm tra, hệ thống sẽ thực hiện lệnh UPDATE (nếu đã có) hoặc INSERT (nếu chưa có) thông qua lớp DAL.
- **Hiển thị:** Khi có phản hồi thành công, giao diện sẽ tính toán lại tỷ lệ phần trăm đã chi tiêu và cập nhật trạng thái màu sắc của thanh tiến trình (Progress Bar).

4.3.4 Chức năng Thêm giao dịch nhanh bằng AI (AI Quick Add)

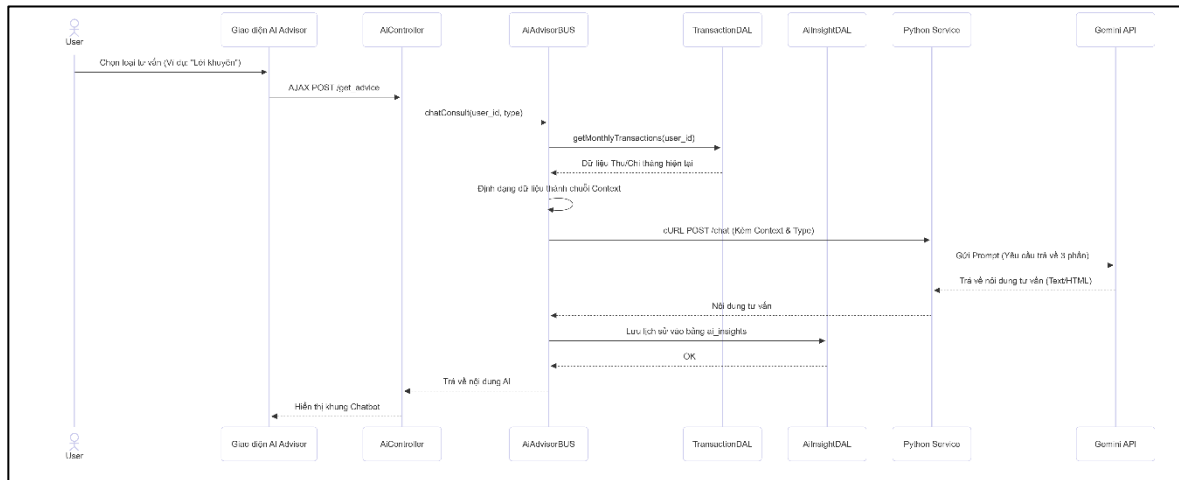


Hình 4-6 Mô tả luồng tự động bóc tách ngôn ngữ tự nhiên thành dữ liệu giao dịch có cấu trúc

Phân tích luồng xử lý:

- **Đầu vào:** Người dùng nhập một câu văn tự do mô tả chi tiêu. Hệ thống gửi chuỗi văn bản này đến AiAdvisorBUS.
- **Bóc tách thực thể (NLP):** Dịch vụ Python sử dụng Gemini API với các kỹ thuật Prompt Engineering để trích xuất các thông tin cốt lõi: Số tiền (Amount), Danh mục (Category) và Ghi chú (Note).
- **Tự động hóa:** Nếu AI bóc tách thành công và dữ liệu hợp lệ, AiAdvisorBUS sẽ trực tiếp ra lệnh cho TransactionDAL lưu giao dịch vào CSDL mà không cần người dùng phải điền form thủ công.
- **Phản hồi:** Hệ thống cập nhật giao diện ngay lập tức để người dùng thấy giao dịch mới vừa được AI "hiểu" và ghi chép lại.

4.3.5 Chức năng Tư vấn AI (AI Advisor)



Hình 4-7 Mô tả luồng tương tác với AI Service để nhận lời khuyên tài chính

Phân tích luồng xử lý:

- **Khởi tạo yêu cầu:** Người dùng chọn loại hình tư vấn trên giao diện (ví dụ: "Lời khuyên"). Giao diện gửi yêu cầu AJAX POST đến AiController.
- **Thu thập dữ liệu tài chính:** AiAdvisorBUS tiếp nhận yêu cầu và thực hiện truy vấn getMonthlyTransactions() thông qua TransactionDAL để lấy dữ liệu thu/chi của tháng hiện tại.
- **Chuẩn bị ngữ cảnh (Context):** BUS thực hiện định dạng lại dữ liệu giao dịch thành chuỗi văn bản ngữ cảnh. Sau đó, một lệnh cURL POST được gửi đến Python Service kèm theo ngữ cảnh và loại tư vấn.
- **Xử lý tại AI Service:** Dịch vụ Python xây dựng Prompt chi tiết (yêu cầu cấu trúc phản hồi 3 phần) và gửi đến Gemini API.
- **Nhận phản hồi:** AI trả về nội dung tư vấn (định dạng Text/HTML). Thông tin này được truyền ngược lại về AiAdvisorBUS.
- **Lưu trữ và Hiện thị:** Lời khuyên của AI được lưu vào bảng ai_insights thông qua AiInsightDAL để lưu lịch sử, sau đó AiController trả kết quả về giao diện để hiển thị khung Chatbot sinh động cho người dùng.

4.4 Thiết kế Bảo mật và Toàn vẹn dữ liệu

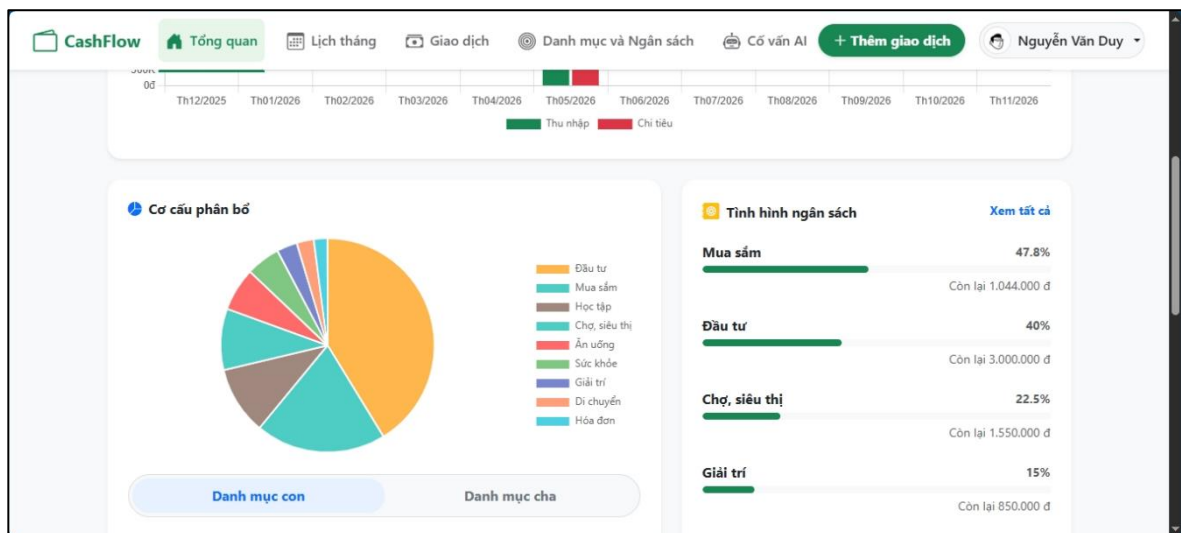
Hệ thống được thiết kế với các tầng bảo mật nghiêm ngặt:

- **Chống CSRF ở tầng ứng dụng:** Sử dụng lớp CsrfHelper để sinh Token ngẫu nhiên cho mọi form POST. Quá trình so khớp sử dụng hàm `hash_equals()` để ngăn chặn tấn công Timing Attack.
- **Chống SQL Injection và mật khẩu được băm ở tầng dữ liệu:** 100% các truy vấn tại tầng DAL sử dụng PDO Prepared Statements với tham số hóa. Mật khẩu được băm bằng thuật toán Bcrypt.
- **Kiểm soát truy cập:** AuthMiddleware chặn mọi truy cập trái phép vào các trang nội bộ nếu chưa có Session hợp lệ.
- **Toàn vẹn giao dịch:** Sử dụng SQL Transactions (`beginTransaction`, `commit`, `rollback`) tại các module nhạy cảm như Xóa tài khoản hoặc Thêm giao dịch để đảm bảo dữ liệu không bị sai lệch nếu có lỗi hệ thống xảy ra giữa chừng.

4.5 Thiết kế Giao diện và Trải nghiệm (UI/UX)

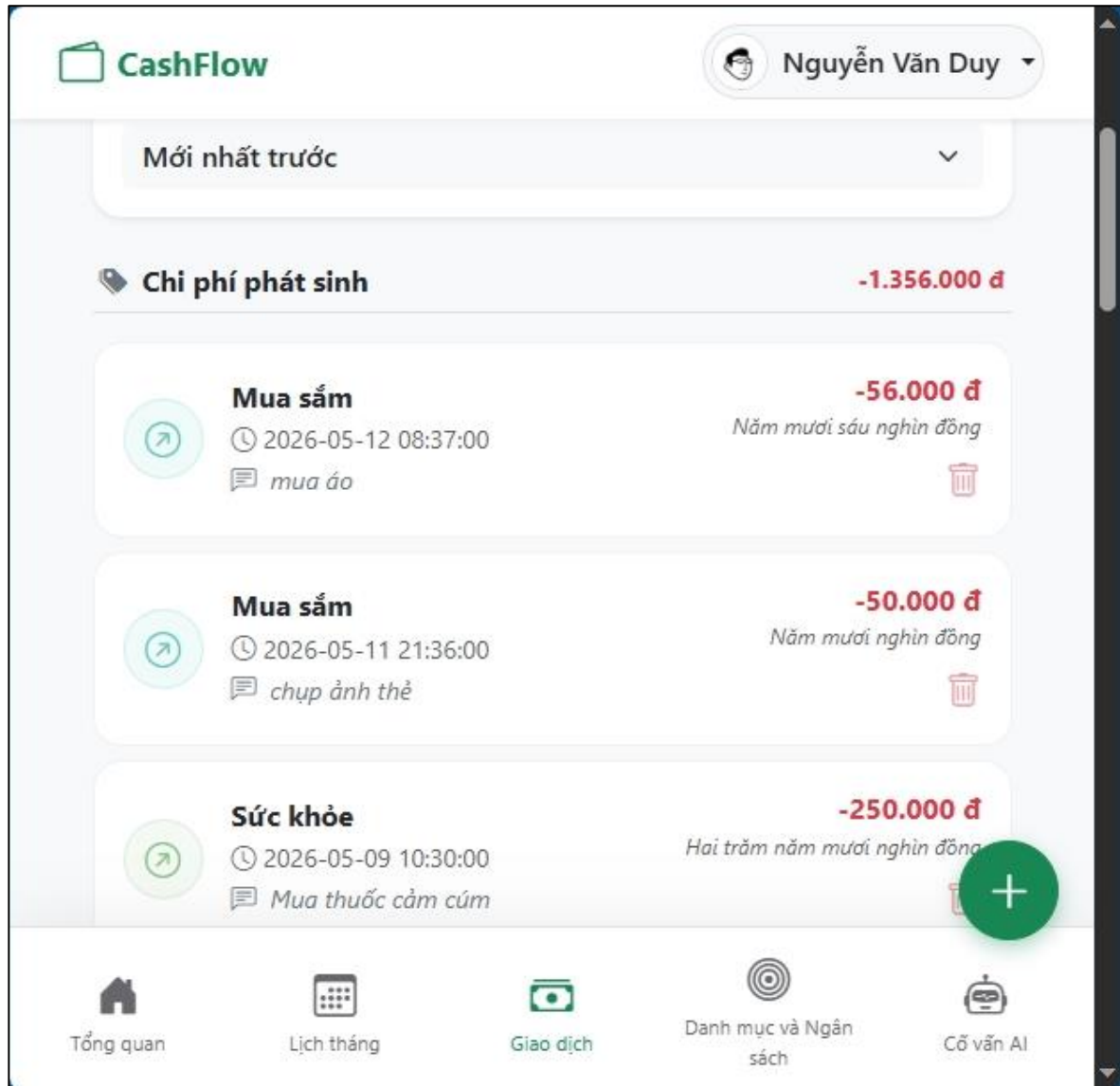
Hệ thống áp dụng phong cách thiết kế hiện đại, tập trung vào trải nghiệm người dùng:

- **Dashboard trực quan:** Sử dụng biểu đồ tròn (Pie chart) và biểu đồ cột (Bar chart) để mô hình hóa dữ liệu khô khan, giúp người dùng dễ dàng nắm bắt tình hình tài chính chỉ trong vài giây.



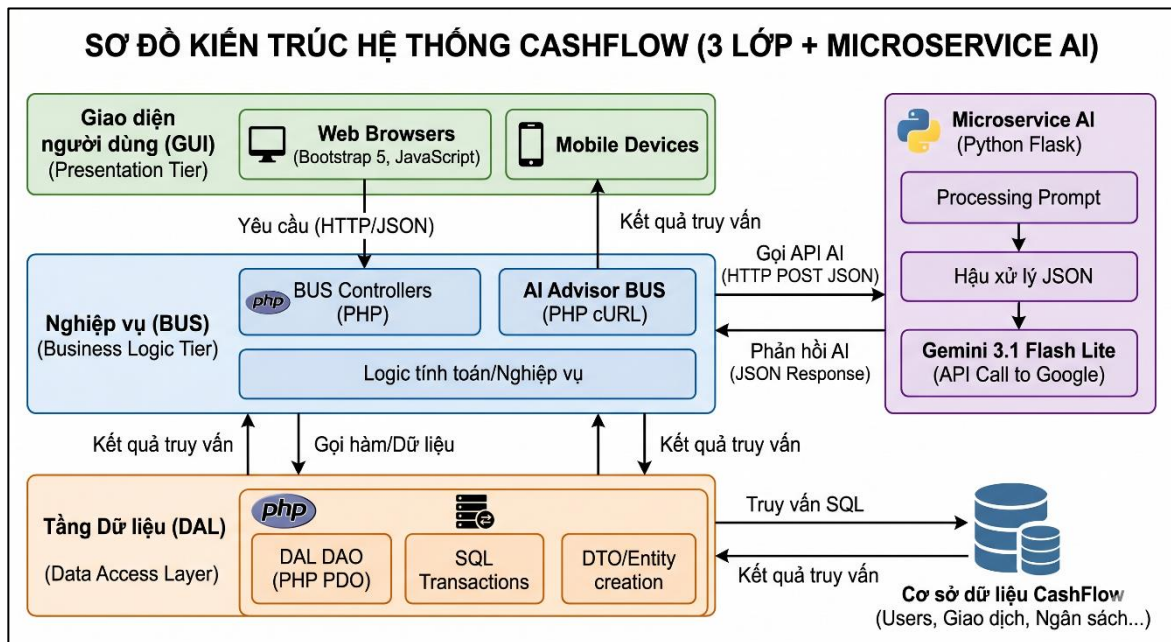
Hình 4-8 Trang tổng quan

- **Thiết kế thích ứng (Responsive):** Giao diện được tối ưu hóa để hiển thị tốt trên cả máy tính để bàn (Desktop) và thiết bị di động (Mobile) thông qua hệ thống Grid linh hoạt của Bootstrap.
- **Trải nghiệm người dùng (UX):** Các nút bấm (như Thêm giao dịch) được đặt ở vị trí thuận tiện, hỗ trợ cả thao tác tay trên di động.



Hình 4-9 Kích thước màn hình nhỏ như thiết bị di động

CHƯƠNG 5. THỰC THI DỰ ÁN



Hình 5-1 Sơ đồ kiến trúc 3 lớp và microservice AI

5.1 Tầng Dữ liệu (Data Access Layer – DAL)

Tầng DAL được thiết kế để tách biệt hoàn toàn logic thao tác cơ sở dữ liệu khỏi các luồng nghiệp vụ bên trên. Dự án áp dụng các tiêu chuẩn an toàn cao nhất trong việc xử lý dữ liệu tài chính.

- **Công nghệ kết nối an toàn:** 100% các truy vấn (Queries) đều sử dụng thư viện PDO (PHP Data Objects). Hệ thống loại bỏ hoàn toàn việc nối chuỗi (String Concatenation) SQL. Thay vào đó, tất cả các tham số từ người dùng đều được ràng buộc qua các hàm `bindParam()` hoặc `bindValue()`. Điều này giúp hệ thống miễn nhiễm hoàn toàn với các cuộc tấn công SQL Injection.
- **Cơ chế toàn vẹn dữ liệu (SQL Transactions):** Trong các thao tác thay đổi dữ liệu trên nhiều bảng cùng lúc, việc cập nhật nửa vời (Partial Update) là tối kỵ. Nhóm đã sử dụng mô hình Transaction (`beginTransaction`, `commit`, `rollback`).
 - *Cụ thể:* Tại hàm xóa tài khoản hoặc xóa một danh mục có chứa nhiều giao dịch con, nếu có lỗi xảy ra giữa chừng, toàn bộ thay đổi sẽ được

hoàn tác (rollback()), đảm bảo không sinh ra hiện tượng "dữ liệu mồ côi" (Orphan Data).

5.2 Tầng Nghiệp vụ (Business Logic Layer - BUS)

Lớp BUS đóng vai trò là "bộ não" điều phối, kiểm soát tính đúng đắn của dữ liệu trước khi lưu trữ và giảm tải các phép tính phức tạp cho phía trình duyệt.

- **Xử lý số liệu ngân sách:** Module BudgetBUS chịu trách nhiệm tính toán tỷ lệ phần trăm và số tiền còn lại (`remain_amount`) giữa hạn mức và thực tế chi tiêu. Dữ liệu này được đóng gói vào BudgetDTO để tầng giao diện dễ dàng dựa vào đó hiển thị thanh cảnh báo (Xanh/Vàng/Đỏ) kịp thời.
- **Tiền xử lý ngữ cảnh cho AI:** Trong chức năng bóc tách giao dịch (Quick Add), để tránh việc AI tự do đoán bừa tên danh mục không khớp với CSDL, AiAdvisorBUS tiến hành truy xuất toàn bộ "Cây danh mục" đang có của chính người dùng đó. Cấu trúc này được "bơm" trực tiếp vào Prompt gửi cho mô hình Gemini, ép buộc AI phải đối chiếu (mapping) và trả về chính xác `category_id` hợp lệ.
- **Kiểm soát lưu lượng và chống Spam:** Do các API AI có giới hạn số lượng truy vấn, AiAdvisorBUS tích hợp thuật toán `checkCooldown`. Hệ thống tự động kiểm tra lịch sử gọi tư vấn của người dùng trong bảng `ai_insights`, nếu vượt quá hạn mức (3 lần/ngày), BUS sẽ tính toán chính xác số giờ chờ còn lại và trả về `can_consult = false` để tầng giao diện khóa nút gửi, bảo vệ máy chủ khỏi nguy cơ bị spam request.

5.3 Tích hợp dịch vụ AI (Python Microservice)

Phân hệ Trí tuệ Nhân tạo được xây dựng theo mô hình Microservice độc lập, chạy bằng Python (Flask) để xử lý các tác vụ phân tích ngôn ngữ phức tạp mà không làm trì trệ luồng chạy chính của Web Server PHP.

- **Prompt Engineering:** Prompt gửi tới mô hình Gemini 3.1 Flash Lite được thiết kế chuyên biệt theo kỹ thuật Strict Output. Bằng cấu hình `response_mime_type="application/json"`, mô hình bị ép buộc chỉ

được phép trả về kết quả dưới dạng chuỗi JSON nguyên gốc. Điều này giúp PHP dễ dàng bóc tách thông tin cốt lõi (Số tiền, ID Danh mục, Ghi chú) mà không gặp lỗi phân tích cú pháp (Parse Error).

- **Kết nối liên tầng:** Hệ thống PHP giao tiếp với dịch vụ Python thông qua thư viện cURL. Các yêu cầu POST được gửi tới endpoint nội bộ (ví dụ: `http://localhost:5000/api/parse`).
- **Tối ưu hóa:** Do đặc thù các mô hình ngôn ngữ lớn (LLM) cần thời gian suy luận (Inference Time), nhóm đã chủ động cấu hình tham số `CURLOPT_TIMEOUT` lên tới 60 giây. Cài đặt này giúp tránh tình trạng rút kết nối (Timeout) khi mạng chậm hoặc hệ thống AI đang quá tải.

5.4 Tầng Giao diện (Graphic User Interface - GUI)

Giao diện CashFlow được thiết kế theo phong cách tối giản (App-like), tuân thủ triết lý Mobile-First để tối ưu hóa trải nghiệm người dùng trên các thiết bị di động.

- **Thiết kế Responsive và Trải nghiệm SPA:** Ứng dụng sử dụng bộ khung Bootstrap 5. Sự kết hợp giữa Fetch API và Toast Notification tạo ra trải nghiệm Single Page Application (SPA). Toàn bộ các tương tác Thêm/Sửa/Xóa và Nhập liệu AI đều được xử lý ngầm (Asynchronous), cập nhật thẳng vào cấu trúc DOM (Document Object Model) mà không bắt buộc người dùng phải tải lại trang.
- **Trực quan hóa dữ liệu:** Hệ thống tích hợp thư viện mạnh mẽ Chart.js.
 - *Biểu đồ tròn:* Hiển thị cơ cấu chi tiêu. Hệ thống tự động phân chia màu sắc hài hòa bằng một thuật toán băm dựa trên chuỗi ký tự tên danh mục, giúp mã màu luôn được giữ cố định, dễ nhớ.
 - *Biểu đồ Bar Chart:* Biểu diễn dòng tiền (Thu - Chi) theo chuỗi thời gian (năm/tháng/tuần). Sự tương phản màu sắc giúp người dùng đánh giá biến động dòng tiền chỉ qua một ánh nhìn.

CHƯƠNG 6. KIỂM THỬ VÀ PHẢN BIỆN AI

6.1 Bảng kịch bản kiểm thử

Nhóm đã tiến hành quá trình kiểm thử đầy đủ 7 module trọng tâm, quan trọng của toàn bộ hệ thống để đảm bảo tính ổn định, chính xác và bảo mật.

6.1.1 Xác thực người dùng (Authentication)

Mã TC	Tên kịch bản	Dữ liệu nhập	Kết quả mong đợi	Trạng thái
TC-AU-01	Đăng ký tài khoản	Thông tin hợp lệ	Tạo user mới, tự động gửi mail kích hoạt	Pass
TC-AU-02	Đăng nhập hệ thống	Đúng email và mật khẩu	Điều hướng vào Dashboard, khởi tạo Session	Pass
TC-AU-03	Quên mật khẩu	Nhập email đã đăng ký	Gửi mật khẩu tạm thời và link đổi mật khẩu vào email người dùng	Pass
TC-AU-04	Bảo mật Session	Truy cập Dashboard khi chưa login	Redirect về trang Login	Pass

6.1.2 Quản lý giao dịch (Transaction Management)

Mã TC	Tên kịch bản	Dữ liệu nhập	Kết quả mong đợi	Trạng thái
TC-TR-01	Thêm giao dịch mới	Số tiền, ngày, danh mục	Giao dịch xuất hiện trong danh sách và biểu đồ	Pass
TC-TR-02	Chỉnh sửa giao dịch	Thay đổi số tiền/ghi chú	Dữ liệu được cập nhật chính xác trong database	Pass

TC-TR-03	Xóa giao dịch	Chọn giao dịch cần xóa	Giao dịch biến mất, số dư Dashboard cập nhật lại	Pass
TC-TR-04	Ràng buộc dữ liệu	Nhập chữ hoặc số âm vào ô số tiền	Không thể nhập	Pass

6.1.3 Quản lý danh mục (Category Management)

Mã TC	Tên kịch bản	Dữ liệu nhập	Kết quả mong đợi	Trạng thái
TC-CA-01	Tạo danh mục mới	Tên danh mục, loại (Thu/Chi)	Xuất hiện trong dropdown khi thêm giao dịch	Pass
TC-CA-02	Danh mục cha/con	Chọn danh mục cha	Danh mục con được phân cấp đúng trên GUI	Pass
TC-CA-03	Xóa danh mục	Danh mục của hệ thống	Hiện thông báo “Đây là danh mục dùng chung của hệ thống, bạn không thể xóa!”	Pass

6.1.4 Quản lý ngân sách (Budget Management)

Mã TC	Tên kịch bản	Dữ liệu nhập	Kết quả mong đợi	Trạng thái
TC-BU-01	Thiết lập hạn mức	Hạn mức cho "Ăn uống": 2tr	Lưu thành công vào bảng budgets	Pass

TC-BU-02	Theo dõi tiến độ	Chi tiêu 1.5tr/2tr	Thanh progress hiển thị 75% màu xanh	Pass
TC-BU-03	Cảnh báo vượt mức	Chi tiêu 2.2tr/2tr	Thanh progress chuyển sang màu đỏ rực	Pass

6.1.5 Ghi chú hàng ngày (Daily Notes)

Mã TC	Tên kịch bản	Dữ liệu nhập	Kết quả mong đợi	Trạng thái
TC-NO-01	Tạo ghi chú	"Hôm nay nhận lương"	Hiển thị trên lịch và danh sách ghi chú của ngày đó	Pass
TC-NO-02	Ghim ghi chú	Chọn ghim theo tuần	Ghi chú luôn hiển thị ở từng tuần trong tháng, bắt đầu từ tháng sau	Pass
TC-NO-03	Xóa ghi chú	Nhấn icon thùng rác	Ghi chú được gỡ bỏ khỏi giao diện	Pass

6.1.6 Cố vấn tài chính AI (AI Advisor)

Mã TC	Tên kịch bản	Dữ liệu nhập	Kết quả mong đợi	Trạng thái
TC-AD-01	Phân tích tổng quát	Yêu cầu "Tóm tắt tháng này"	AI trả về định dạng HTML (Tổng quát/Cụ thể/Kết luận)	Pass
TC-AD-02	Cảnh báo chi tiêu	Nhấp nút "Cảnh báo"	AI chỉ ra các khoản chi bất thường như	Pass

			số dư đang âm vì nguồn thu không có	
TC-AD-03	Giới hạn lượt hỏi	Hỏi 3 lần trong 15 phút	Thông báo "Bạn đã hết lượt tư vấn hôm nay"	Pass

6.1.7 Thêm nhanh bằng AI (AI Quick Add)

Mã TC	Tên kịch bản	Dữ liệu nhập	Kết quả mong đợi	Trạng thái
TC-QA-01	Bóc tách cơ bản	"Cơm trưa 35k"	Tự điền Amount: 35000, Cat: Ăn uống	Pass
TC-QA-02	Nhận diện từ lỏng	"Nạp game 2 xì"	Tự điền Amount: 200000, Cat: Giải trí	Pass

6.2 Nhật ký Virtual Tech Lead Audit (Phản biện và Tối ưu)

Trong suốt vòng đời phát triển phần mềm (SDLC), nhóm không chỉ tập trung vào việc viết mã mà còn tự đóng vai trò là các Tech Lead để liên tục rà soát mã nguồn (Code Review) và tái cấu trúc (Refactoring). Dưới đây là 4 đợt Audit quan trọng nhất đã cứu hệ thống khỏi các lỗi nghiêm trọng.

6.2.1 Đợt rà soát 1: Vi phạm nguyên tắc 3 tầng (Kiến trúc)

- Vấn đề phát hiện:** Trong các phiên bản đầu, một số tệp Controller (như `BudgetController.php`) thực hiện việc kiểm tra logic kinh doanh và gọi trực tiếp các câu lệnh SQL ở tầng DAL, bỏ qua hoàn toàn tầng BUS. Điều này vi phạm nghiêm trọng tính Đóng gói.
- Hành động:** Nhóm tiến hành tách bạch lại luồng dữ liệu. Controller được làm mỏng lại, chỉ nhận request và trả JSON. Toàn bộ logic (ví dụ: tự động kế thừa

ngân sách) được chuyển giao hoàn toàn vào BudgetBUS, và chỉ có BudgetDAL mới được phép giữ các lệnh PDO prepare().

6.2.2 Đợt rà soát 2: Nút thắt hiệu năng AI - cURL Timeout (Hiệu năng)

- **Vấn đề phát hiện:** Các mô hình ngôn ngữ lớn (LLM) như Gemini đôi khi cần hơn 30 giây để suy luận. Tuy nhiên, giới hạn thời gian chờ (Timeout) mặc định của hàm cURL trong PHP quá ngắn. Hệ quả là phía GUI thường xuyên nhận lỗi "HTTP 0" hoặc "Internal Server Error" gây trắng trang.
- **Hành động:** Cấu hình lại hàm cURL tại AiAdvisorBUS.php với tham số `CURLOPT_TIMEOUT => 60` (chờ tối đa 60 giây). Đồng thời bổ sung cơ chế xử lý ngoại lệ. Thay vì sập hệ thống, ứng dụng giờ đây bắt lỗi và trả về một thông báo hiện rõ mã lỗi: `[ "status" => false, "error" => "HTTP $code" ]`.

6.2.3 Đợt rà soát 3: Lỗ hổng bảo mật tại AI Service Flask (Bảo mật)

- **Vấn đề phát hiện:** Phân hệ Python (`app.py`) ban đầu được khởi chạy với cờ `debug=True`. Ở chế độ này, trình gỡ lỗi của Werkzeug/Flask sẽ hiển thị toàn bộ Stack Trace và cấu trúc thư mục Server nếu có lỗi xảy ra. Tệ hơn, kẻ tấn công có thể lợi dụng console gỡ lỗi để thực thi mã từ x.
- **Hành động:** Cách đơn giản nhất là chuyển đổi mã nguồn sang trạng thái Production bằng cách thiết lập `debug=False`. Bọc toàn bộ quá trình gọi thư viện `google.genai` vào khối `try...except`. Máy chủ Python được thiết lập không bao giờ trả về lỗi thô mà luôn trả về một chuỗi JSON an toàn nhằm ẩn giấu thông tin hệ thống.

6.2.4 Đợt rà soát 4: Bảo mật API Key (Dịch vụ AI)

- **Vấn đề phát hiện:** Trong giai đoạn đầu, API Key của Gemini thường được nhóm gắn cứng trực tiếp trong code và chia sẻ qua các kênh chat không an toàn (như Messenger chưa mã hóa đầu cuối) để nhóm tiện hỗ trợ nhau kiểm thử.

- **Hậu quả:** Các nhà cung cấp dịch vụ như Google có hệ thống quét tự động rất rộng và kỹ. Vì nhóm đã vô tình để lọt API Key lên các nền tảng công khai (push code lên Github) và gửi qua tin nhắn không mã hóa, Google đã phát hiện và ngay lập tức vô hiệu hóa key đó, khiến toàn bộ hệ thống AI bị hỏng.
- **Hành động:**
 - Tuyệt đối không điền trực tiếp API Key vào mã nguồn.
 - Chuyển toàn bộ cấu hình nhạy cảm vào tệp `.env`.
 - Cấu hình tệp `.gitignore` chặt chẽ để đảm bảo không bao giờ đẩy khóa bảo mật lên hệ thống quản lý phiên bản (Git/Github).
 - Quán triệt việc bảo mật thông tin nội bộ, chỉ sử dụng các kênh truyền tin an toàn và mã hóa khi cần thiết.
 - Thực tế, nhóm đã thống nhất mỗi người sẽ tự cấu hình API Key AI để có thể sử dụng chức năng AI tốt nhất, vừa tiết kiệm tokens, vừa tăng tính bảo mật của API.

CHƯƠNG 7. TỔNG KẾT

7.1 Kết quả đạt được

Dự án CashFlow đã hoàn thiện các module chức năng chính, tạo ra một hệ sinh thái quản lý tài chính khép kín:

- **Hệ thống Quản lý cốt lõi:** Hoàn thiện các tính năng Đăng ký/Đăng nhập, Quản lý hồ sơ cá nhân, Quản lý giao dịch (Thu/Chi), Quản lý danh mục đa cấp và Thiết lập ngân sách hàng tháng.
- **Trí tuệ nhân tạo (AI Integration):**
 - **Module AI Advisor:** Phân tích dữ liệu thực tế để đưa ra cảnh báo, lời khuyên và dự báo tài chính dưới dạng HTML trực quan.
 - **Module AI Quick Add:** Cho phép thêm giao dịch nhanh bằng ngôn ngữ tự nhiên, tự động bóc tách số tiền và phân loại danh mục.
- **Trực quan hóa dữ liệu:** Hệ thống biểu đồ đa dạng (Doughnut, Bar Chart) giúp người dùng có cái nhìn tổng thể về dòng tiền.

- **Kiến trúc và Bảo mật:** Triển khai mô hình 3 lớp chuẩn, bảo mật Session, chống CSRF và quản lý cấu hình nhạy cảm qua biến môi trường (.env)

7.2 Hạn chế

Thông qua quá trình rà soát hệ thống, nhóm đã xác định được các hạn chế kỹ thuật cụ thể:

- **Hiệu suất truyền tải dữ liệu AI:** Hiện tại, hệ thống gửi toàn bộ danh sách giao dịch thô sang Python Service để tính toán tổng thu chi. Khi số lượng giao dịch lên đến hàng ngàn, việc này sẽ gây trễ mạng và tiêu tốn nhiều Token không cần thiết.
- **Cấu trúc Cơ sở dữ liệu:** Bảng transactions hiện thiếu các chỉ mục tổng hợp (Composite Indexes) trên bộ đôi (user_id, transaction_date), điều này có thể làm chậm tốc độ truy vấn báo cáo khi dữ liệu lớn dần theo thời gian.
- **Quản lý xóa dữ liệu:** Hệ thống chưa có cơ chế "Xóa mềm". Các giao dịch khi bị xóa sẽ mất vĩnh viễn khỏi DB, không có khả năng khôi phục nếu người dùng thao tác nhầm.
- **Tính đa dụng:** Ứng dụng hiện đang được thiết kế cứng cho đơn vị tiền tệ VNĐ và ngôn ngữ Tiếng Việt, chưa linh hoạt cho các thị trường hoặc nhu cầu sử dụng ngoại tệ khác.

7.3 Hướng phát triển tương lai

Dựa trên các hạn chế đã rà soát, nhóm đề xuất lộ trình nâng cấp cụ thể:

- **Tối ưu hóa RAG (Retrieval-Augmented Generation):** Thực hiện tính toán tổng hợp (Aggregate) dữ liệu ngay tại tầng SQL trước khi gửi sang AI. Chỉ gửi các "Insight" quan trọng thay vì dữ liệu thô để tối ưu hóa Token và tốc độ phản hồi.
- **Tính năng Xóa mềm và Thùng rác:** Bổ sung cột deleted_at và module Thùng rác để người dùng có thể khôi phục dữ liệu trong vòng 30 ngày.

- **Hỗ trợ Đa tiền tệ và Tỷ giá:** Tích hợp API tỷ giá ngoại tệ để người dùng có thể quản lý các khoản chi bằng USD, EUR... và tự động quy đổi về tiền tệ cơ sở.
- **Hệ thống Hội viên VIP:** Phát triển các gói thành viên cao cấp để nâng cấp trải nghiệm AI:
 - **Tăng giới hạn Request:** Người dùng VIP có thể sử dụng AI Advisor không giới hạn thay vì mức 3 lượt/ngày.
 - **AI Quick Add nâng cao:** Sử dụng các mô hình LLM mạnh hơn (như Gemini 1.5 Pro) để bóc tách các câu lệnh cực kỳ phức tạp hoặc đa ý đồ.
 - **Hội thoại trực tiếp:** Cho phép người dùng chat tự do với AI để hỏi về tài chính cá nhân thay vì chỉ giới hạn trong các nút chức năng có sẵn.
- **Smart Search với Vector DB:** Nâng cấp hệ thống tìm kiếm từ SQL thuần sang Vector Search (sử dụng Pinecone hoặc ChromaDB) kết hợp với Embedding để tìm kiếm giao dịch theo ý nghĩa ngữ nghĩa thay vì chỉ tìm theo từ khóa.
- **Tích hợp quét hóa đơn (OCR):** Sử dụng công nghệ nhận dạng ký tự quang học để người dùng chỉ cần chụp ảnh hóa đơn, hệ thống sẽ tự động bóc tách thông tin và lưu vào DB.

TÀI LIỆU THAM KHẢO

1. PHP Documentation, "PHP Manual," : <https://www.php.net/manual/en/>.
2. MySQL Documentation, "MySQL 8.0 Reference Manual," : <https://dev.mysql.com/doc/refman/8.0/en/>.
3. Google Gemini API, "GenAI SDK for Python Documentation," : <https://ai.google.dev/docs>.
4. Flask Documentation, "Flask Web Development," : <https://flask.palletsprojects.com/>.
5. Chart.js, "Interactive Charts for Designers and Developers," : <https://www.chartjs.org/>.
6. OWASP Foundation, "Top Ten Security Risks," : <https://owasp.org/www-project-top-ten/>.
7. PHP: The Right Way, "Best Practices for PHP Development," : <https://phptherightway.com/>.